

Setnayan — Data Retention Schedule

Status: DRAFT — [PENDING COUNSEL]. Retention periods below are reasoned from the standard PH statutes (RA 10173, NIRC/BIR, Civil Code). They are **not legal advice** and must be ratified by external counsel before launch. **DPO = the owner** (Indalecio S. Casasola II) per `[[dpo-designation-owner]]`; external counsel = TBD.

Created 2026-07-11. This is the canonical answer to "how long do we keep user data, and until when *can* we keep it?" — supersedes scattered "5-year" mentions in individual iteration specs.

1. Governing principles

Retention is bounded on **both** ends, and the two bounds come from different laws pulling in opposite directions:

Bound	Source	Effect
Maximum (delete <i>by</i>)	RA 10173 (Data Privacy Act) — storage-limitation principle	Personal data may be kept only as long as necessary for its purpose, then must be securely disposed of. Indefinite retention of personal data is itself a violation and a breach-surface liability. "Keep everything forever" is not an option for personal data.
Minimum (cannot delete <i>before</i>)	NIRC / BIR RR 17-2013 ; Civil Code Art. 1144	Financial/tax records must be kept 10 years ; a written contract is actionable for 10 years , so contract records must survive that dispute window. These override an earlier RA 10173 erasure for the specific records they cover.

Design consequence: a chat thread and the payment attached to it are **different retention classes**. You cannot anchor everything to one "delete at N years" switch — you would either illegally delete a tax record or needlessly hoard chat. Retention is **per data class**, below.

2. Retention schedule (by data class)

#	Data class	Iteration(s)	Retention anchor	Keep for	Legal basis	Disposal
1	Vendor↔couple chat (chat_threads, chat_messages)	0019	event_date	5 years	RA 10173 necessity + normal dispute window	Hard-delete thread + messages
2	Media — Paptic photos/video, gallery, reels (R2)	0012, 0009, 0024	event_date	5 years (hot 90 d → cold → purge)	RA 10173; PH photographer norm	R2 lifecycle expiry

3	Payments / receipts / Official Receipts	0026, 0034	payment date	10 years — <i>legal floor, cannot delete early</i>	BIR RR 17-2013	Purge at 10 y
4	Contracts + e-signatures	0032	contract execution date	10 years	Civil Code Art. 1144 prescription	Purge at 10 y
5	Account / profile PII (users, settings)	0025	account close / deletion request	Life of account + 30–90 day tail , then purge	RA 10173 storage limitation	Soft-delete → hard-delete after tail
6	Face-recognition vectors (face_enrollments)	0012	event_date	Per-event only; revocable on request; purge with media (≤5 y)	RA 10173 sensitive data; per-event-scoped lock	Delete on revoke or at media purge
7	Marketing consent / comms prefs	0025, 0028	last consent change	Life of account + audit tail	RA 10173 / CAN-SPAM proof-of-consent	Purge with account
8	Support tickets / help-center	0029	ticket close	2 years	Operational necessity	Purge at 2 y
9	Observability / logs (Sentry, PostHog)	0035	event timestamp	Provider default (≤ 90 days); no PII in logs	RA 10173 data-minimization	Provider TTL
10	Device-fingerprint hashes (user_devices, device_hash) — fraud prevention	Fake-Inquiry Protection (DeviceHash)	last_seen_at	Life of account ; rolling-prune device rows unused > 24 mo (proposed)	RA 10173 §12(f) legitimate interest (fraud prevention); pseudonymous, non-sensitive	Purge with account (class 5 tail) or on rolling prune

The two clocks, stated plainly

- **Default = 5 years** for the *experience* data (chat + media), anchored to `event_date` so a wedding's whole record ages together.
- **Legal-hold floor = 10 years** for anything touching **money or a contract** — flagged and **exempt** from the 5-year sweep.

3. Right-to-erasure interaction (RA 10173 §16)

A user's erasure/account-deletion request (iteration 0025) deletes their personal data **now**, **except** records under a legal-hold floor (classes 3 & 4 — payments, contracts), which are **retained under the legal-obligation basis** and disclosed as such in the privacy policy.

This carve-out is standard and defensible: "We honor deletion requests except where law requires us to retain financial and contractual records, which we keep for the statutory period and then dispose of."

4. Implementation reality (as of 2026-07-11)

Audited against shipped code — **the retention plumbing is greenfield**; almost none of this is enforced yet:

- **Chat** (`chat_threads` / `chat_messages`): text-only, append-only, no attachments. **No** `archived_at` / retention / soft-delete columns. `chat_threads.updated_at` already tracks last activity (free `last_message_at`).
- **R2 lifecycle: NOT configured** — hot→cold tiering + expiry exist only as prose in `OWNER_ACTIONS.md` and marketing copy. No `wrangler.toml`/Terraform in the repo. **This is the real space program** (media = gigabytes; chat = megabytes).
- **No cleanup cron** touches chat/media. House style deliberately avoids `pg_cron` (uses Vercel cron + on-access sweeps).
- **■ Compliance gap**: account hard-delete (`admin/users/actions.ts` → `deleteUser`) sets chat user-FKS to NULL but **leaves message bodies (the couple's PII) in `chat_messages` indefinitely** — threads only cascade on *event* delete, and events are never deleted. Fixing this is part of enforcing class 1 & 5.

Build order to enforce this schedule

1. **Archive (UX, zero deletion)** — add `archived_at` to `chat_thread_reads` (per-user); inbox filter `archived_at IS NULL OR chat_threads.updated_at > archived_at` (Viber-style: a new message un-archives). Ships safely on its own.
2. **R2 lifecycle** — actually configure bucket rules for class 2 (the gigabyte win).
3. **Retention sweep** — weekly Vercel cron `/api/cron/retention-sweep`: hard-delete class 1/2 at anchor + 5 y; **skip** any thread/record tied to an active legal hold (class 3/4). Fix the account-deletion residue in the same job.

5. Open items for counsel [PENDING COUNSEL]

1. Confirm **BIR retention = 10 years** for in-app SKU payments + Official Receipts (RR 17-2013) and the exact record scope.
2. Confirm **contract retention** period + whether e-signature audit trails (RA 8792) extend it beyond 10 years.
3. Ratify the **5-year default** for chat + media as "necessary" under RA 10173 §11(e).
4. Approve the **erasure carve-out** wording (§3) for the privacy policy.
5. Confirm **face-vector** treatment as sensitive personal information and the per-event purge rule.
6. Sign off on **device-fingerprint hashes** (class 10) — legal basis (legitimate interest vs consent), notice wording, and the 24-month rolling-prune period. See the dedicated one-pager `Device_Fingerprint_Data_Use_DPO_Review_2026-07-12.md`.

Related: `[[dpo-designation-owner]] · 0025_profile_settings/ · 0026_bir_tax_compliance/ · 0032_contract_intelligence/ · 0019_communications/ · Pricing.md § 2.1 (media storage/longevity ladder)`.